CYBERSECURITY TECHNICAL RESEARCH REPORT

Ransomware Preparedness

Prevention, Detection, Containment, Communication and Recovery

PREPARED BY **Kritika Rani**

INTERN ID **2428**

ORGANIZATION **RedKross Research Foundation**

SUBMISSION DEADLINE **25 October 2026**

PREVENT | DETECT | CONTAIN | COMMUNICATE | RECOVER

Defensive research for authorized organizational use. Not legal advice.

Table of Contents

1. Executive Summary . . . 3

2. Introduction and Objectives . . . 4

3. Background Research and Literature Review . . . 5

4. Methodology and Tools . . . 6

5. Ransomware Preparedness Framework . . . 7

5.1 Prevention . . . 7

5.2 Detection . . . 8

5.3 Containment . . . 9

5.4 Communication . . . 9

5.5 Recovery . . . 10

5.6 Safe Escalation . . . 11

6. Implementation Roadmap . . . 11

7. Findings, Results and Testing . . . 12

8. Limitations and Recommendations . . . 13

9. Conclusion . . . 14

10. References and Appendices . . . 15

Page numbers are generated automatically from the document structure.

1. Executive Summary

Ransomware is a cybersecurity threat in which attackers deny access to systems or data, usually through encryption, and demand payment. Modern operations frequently add data theft and the threat of publication, so restoring files from backup resolves only part of the harm. A resilient response therefore depends on more than antivirus software: it requires coordinated prevention, early detection, safe containment, trusted communication and tested recovery.

This report presents a practical preparedness framework informed by public guidance from NIST, CISA and CERT-In. It covers backup resilience, least privilege, vulnerability and patch management, endpoint and log monitoring, incident escalation, communication and restoration. The framework is organised around six activities (prevention, detection, containment, communication, recovery and safe escalation) and mapped to the six functions of NIST Cybersecurity Framework 2.0.

Central recommendation

Build layered controls and test them regularly. Isolated, immutable and restore-tested backups reduce recovery risk; MFA and least privilege limit the impact of stolen credentials; endpoint, identity and backup monitoring reveal suspicious behaviour early; and documented escalation authority lets responders act before damage spreads.

The report also provides an indicator-based detection guide, a 90-day implementation roadmap, readiness metrics and a tabletop exercise. Numeric targets are illustrative starting points and must be adjusted to organisational risk, size, legal duties and operational needs.

Keywords: ransomware, incident response, immutable backups, EDR, SIEM, least privilege, patch management, NIST CSF 2.0, business continuity, recovery.

2. Introduction and Objectives

2.1 What is ransomware?

Ransomware is malicious software, or an attack operation built around it, that denies access to systems or data and demands payment for restoration. In many incidents operators also steal data before encrypting it ("double extortion") and threaten to publish it. Common entry routes include phishing, stolen or reused credentials, exposed remote-access services, unpatched internet-facing systems and compromise of a third-party supplier or managed service provider.

2.2 Why it matters

- **Financial impact:** incident response, restoration, consulting, legal and downtime costs.
- **Operational disruption:** interruption to business services, teaching, customer support or production.
- **Confidentiality risk:** personal, financial or proprietary information may be exposed.
- **Trust and reputation:** customers, students, suppliers and partners may lose confidence.
- **Compliance risk:** privacy, sectoral, contractual and incident-reporting obligations may apply.
- **Safety risk:** disruption to healthcare or industrial environments can have physical consequences.

2.3 Objectives

1. Explain ransomware attack patterns and the risks they create.
2. Identify practical controls that reduce both the likelihood and the impact of compromise.
3. Define monitoring signals, detection logic and safe escalation actions.
4. Establish containment, communication and recovery procedures.
5. Recommend an implementation roadmap and measurable preparedness indicators.

2.4 Scope and audience

This is a defensive, desk-based research report for authorised organisational use by IT teams, SOC analysts, educational institutions and management. It does not contain offensive techniques, does not replace a tailored risk assessment or legal advice, and does not claim results from a live environment. Procedures should be adapted to the local environment and rehearsed before an emergency.

2.5 The attack lifecycle at a glance

Understanding how an intrusion typically unfolds shows where each defensive layer applies. Most operations progress through the stages below, and every stage offers an opportunity to detect or stop the attacker.

Initial access	Foothold and discovery	Privilege and movement	Defense and backup attack	Exfiltration and impact
Phishing, stolen credentials, exposed RDP/VPN, unpatched edge devices	Remote tools, scripts, network and AD enumeration	Credential theft, domain admin, lateral movement	Disable EDR, delete shadow copies and backups	Data theft, mass encryption, extortion note

Figure 1. Typical ransomware intrusion stages (simplified, based on public CISA and NIST descriptions).

3. Background Research and Literature Review

3.1 Key sources

Source	Main contribution	Use in this report
NIST IR 8374 Rev. 1 (final, June 2026)	Ransomware risk management profile aligned to Cybersecurity Framework 2.0 (Govern, Identify, Protect, Detect, Respond, Recover)	Risk assessment, control planning and CSF mapping
CISA #StopRansomware Guide	Prevention, preparation, response and recovery checklists	Operational checklists and containment steps
NIST SP 800-61 Rev. 3 (2025)	Incident response integrated into cybersecurity risk management	Response lifecycle and governance
CERT-In	Indian ransomware advisory and 2022 incident-reporting directions	Local escalation and reporting considerations
MITRE ATT&CK	Public knowledge base of adversary tactics and techniques	Detection mapping (Section 5.2)
Vendor guidance (e.g. Microsoft)	Endpoint, identity and platform hardening practices	Technical control examples

Table 1. Principal sources reviewed.

3.2 Key findings

- Backups must be isolated from production compromise and verified by **restoration testing**, not merely by successful backup-job status.
- Least privilege and MFA limit the damage caused by stolen credentials and administrative misuse.
- Prompt patching and a reduced internet-facing footprint remove common initial-access opportunities.
- Endpoint and centralised log monitoring support earlier identification of suspicious behaviour.
- Incident response needs defined roles, independent communication channels, evidence preservation and controlled recovery.
- Exercises and post-incident reviews convert written plans into measurable capability.

3.3 Mapping to NIST CSF 2.0

CSF 2.0 function	Purpose	Where addressed
Govern	Set risk strategy, roles, policy and oversight	Sections 5.4, 6 and 8
Identify	Know assets, suppliers and risks	Sections 5.1 and 6
Protect	Safeguards: access control, backups, patching, training	Section 5.1
Detect	Find anomalies and compromise events	Section 5.2
Respond	Triage, contain, communicate, escalate	Sections 5.3, 5.4 and 5.6
Recover	Restore services and capabilities safely	Section 5.5

Table 2. Alignment of this framework with CSF 2.0 functions.

3.4 Interpretation

The sources converge on a layered approach: no single tool prevents every attack. Resilience comes from reducing the attack surface, detecting suspicious behaviour, limiting movement, preserving recoverable data

and rehearsing decisions before an incident occurs.

4. Methodology and Tools

4.1 Research methodology

Stage	Activity	Output
1. Literature review	Review public guidance from NIST, CISA and CERT-In; verify publication status and dates	Source-backed control baseline
2. Analysis	Compare recurring recommendations and operational dependencies	Prioritised risk themes
3. Framework design	Group controls into prevention, detection, containment, communication, recovery and escalation	Preparedness model
4. Evaluation design	Define metrics, a tabletop scenario and recovery checks	Readiness measurement plan

Table 3. Research stages.

4.2 Tools and technologies

- Windows and Linux security logs for host and authentication events.
- Endpoint Detection and Response (EDR) for telemetry, investigation and approved isolation actions.
- Security Information and Event Management (SIEM) for log collection, correlation and alert management.
- Backup platforms with encryption, immutable retention and restore testing.
- Vulnerability scanners and patch-management tools for inventory and remediation.
- Firewalls, network segmentation and secure remote-access gateways.
- Ticketing, contact lists, evidence registers and recovery runbooks.

4.3 Evaluation approach and integrity statement

This report uses scenario-based reasoning and proposed indicators. It does not claim a live enterprise deployment. Any sample figure must be replaced with recorded evidence before it is presented as a measured outcome. Source details were checked against the publishers' pages; the user of this report should re-confirm regulatory text (especially CERT-In directions) at the time of use.

5. Ransomware Preparedness Framework

Figure 2. Preparedness and response workflow with a continuous improvement loop.

5.1 Prevention

Objective: reduce the chance of initial compromise and limit an attacker's ability to reach critical systems.

Backup resilience

- Use 3-2-1 as a baseline (three copies, two media types, one off-site); stronger variants add an offline or immutable copy and verified zero errors after restore testing.
- Keep offline or logically isolated copies and consider immutable (write-once) retention.
- Encrypt backups; restrict backup administration to separate accounts with MFA, outside the normal domain admin population.
- Protect system configurations, identity dependencies (for example directory services) and recovery keys.
- Test file, database, application and full-system restoration on a defined schedule.
- Set recovery point objectives (RPO), recovery time objectives (RTO) and retention periods.

Least privilege and identity security

- Remove administrator rights from everyday user accounts; separate standard and privileged accounts.
- Enforce MFA for remote access, email, cloud consoles and all privileged users; prefer phishing-resistant methods where feasible.
- Review group membership, service accounts and inactive accounts on a regular cycle.
- Revoke sessions and rotate credentials in sequence when compromise is suspected.

Patching and attack-surface reduction

- Maintain an asset and software inventory, including every internet-facing service.
- Prioritise vulnerabilities by exploitability, exposure, criticality and evidence of active exploitation (for example CISA's Known Exploited Vulnerabilities catalog).
- Apply security updates within risk-based timeframes and verify deployment.
- Isolate or mitigate systems that cannot be patched; replace unsupported software.
- Disable unnecessary services and restrict exposed remote administration such as RDP.

Email, web and network controls

- Filter malicious attachments and URLs; configure SPF, DKIM and DMARC.
- Restrict untrusted scripts and macros; use application control where feasible.
- Segment endpoints, servers, backup infrastructure and management networks; permit only necessary east-west traffic.
- Train staff to report suspicious messages and unusual login or file activity quickly and without blame.

Prevention principle

Assume any single control may fail; rely on multiple independent layers.

5.2 Detection

Objective: identify ransomware behaviour or precursor activity early enough to reduce damage.

5.2.1 High-value signals

Signal	Possible meaning	Analyst action
Mass file changes or renames	Encryption or destructive activity	Correlate process, user, path and time
Ransom note or unusual file extensions	Ransomware execution	Escalate; isolate under approved procedure
Unexpected privileged login	Credential misuse	Verify source, device, MFA and session
New admin account or service	Persistence or privilege escalation	Validate authorisation and creator
Security tooling disabled or logs cleared	Defense evasion	Investigate tamper events; preserve telemetry
Backup deletion or retention change	Recovery sabotage	Protect backup plane; notify incident lead
Unusual outbound data transfer	Possible exfiltration	Review destination, volume, authorisation

Table 4. Signals that warrant investigation.

5.2.2 Detection mapping to MITRE ATT&CK and log sources

The table maps behaviours commonly seen in ransomware intrusions to ATT&CK techniques and to log sources a SOC can monitor. Event IDs are standard Windows events; they should be validated against the organisation's audit policy because many require specific auditing to be enabled.

Behaviour	ATT&CK technique	Log source / indicator
Phishing delivering initial payload	T1566 Phishing	Email gateway, EDR child-process alerts from office applications
Use of stolen credentials	T1078 Valid Accounts	Security 4624/4625 anomalies; impossible-travel and new-device sign-ins
New privileged account or group change	T1136 Create Account; T1098	Security 4720, 4728, 4732, 4756
New service installed for persistence	T1543 Create or Modify System Process	System 7045; Security 4697
Disabling or tampering with security tools	T1562 Impair Defenses	EDR tamper alerts; service stop events; Security 1102 (audit log cleared)
Deleting shadow copies or backups	T1490 Inhibit System Recovery	Process creation (4688/Sysmon 1) for backup-deletion utilities; backup console audit logs
Data staging and exfiltration	T1567 Exfiltration over Web Service	Proxy and firewall volume anomalies; cloud storage uploads
Mass encryption of files	T1486 Data Encrypted for Impact	File-integrity telemetry, high rename/write rates, canary-file alerts

Table 5. Detection mapping (technique IDs per MITRE ATT&CK).

5.2.3 EDR, SIEM and canary files

EDR provides endpoint telemetry and, where authorised, controlled isolation. A SIEM aggregates and correlates logs from endpoints, identity systems, servers, firewalls and cloud services. **Canary (decoy) files**

placed in file shares and monitored for modification give a low-noise early warning of mass encryption. None of these replaces analyst judgement or sound preventive controls.

5.2.4 Detection workflow

1. Validate the alert source, timestamp, host, account and process.
2. Correlate related endpoint, identity, network and backup events.
3. Classify the activity as authorised, suspicious or confirmed malicious.
4. Assign severity and notify the designated incident-response lead.
5. Record evidence and start approved containment when the risk warrants it.

A single indicator does not prove ransomware, and context matters. However, credible signs of active spread should be escalated immediately rather than held for further proof.

5.3 Containment

Objective: stop further spread and protect recovery resources while preserving evidence.

1. Report the alert through the approved security or IT incident channel.
2. Isolate affected endpoints using approved EDR or network controls; consider wider segmentation if several systems are affected.
3. Activate the incident commander and notify security, infrastructure, backup and business owners.
4. Preserve logs, alert records, timestamps and forensic evidence as appropriate.
5. Restrict compromised accounts, revoke sessions and rotate exposed credentials in a coordinated sequence.
6. Protect backup consoles and repositories; investigate deletion or retention changes.
7. Document every major action, decision, time and responsible person.

Do	Avoid
Use approved isolation procedures and escalate promptly.	Waiting for a ransom note before responding.
Preserve logs and evidence in secure storage.	Wiping systems before evidence needs are assessed.
Use independent, verified communication channels.	Assuming corporate email and chat remain trustworthy.
Protect backup administration and clean copies.	Connecting unverified backups to clean systems.
Coordinate shutdown decisions with responders when feasible.	Powering off every device automatically without weighing evidence and safety.

Table 6. Containment do and avoid. When harm is imminent, stopping spread and protecting safety take priority; qualified responders balance volatile-evidence preservation against urgency.

5.4 Communication

Objective: give timely, accurate information while preventing confusion and unnecessary disclosure.

- Use verified, independent channels if email, identity systems or chat may be compromised.
- Name an incident commander and an authorised spokesperson.
- Separate confirmed facts from hypotheses and unknowns.
- Share technical detail only with those who need it to respond.
- Keep a decision log of who was notified, when and by whom.

- Consult legal, privacy and compliance teams on notification duties.

Stakeholder	Information needed	Owner
Executives	Business impact, decisions, risks, recovery status	Incident commander
SOC and IT	Assets, alerts, containment actions, priorities	Security lead
Staff / students	Service status, safe actions, approved alternatives	Internal communications
Customers / partners	Verified impact, precautions, next update time	Authorised spokesperson
Legal / privacy	Potential exposure, evidence, applicable deadlines	Legal / privacy lead
Authorities / regulators	Required reports and incident details	Authorised representative

Table 7. Stakeholder communication plan.

Sample internal notice (adapt and obtain approval before use)

Subject: Urgent Security Incident: Investigation Underway
We are investigating suspicious activity affecting certain IT systems. The scope and impact are still being assessed. Do not reconnect affected devices or try to remove suspected malware yourself. Report unusual activity through the approved incident channel. Further updates will be shared through verified official channels. Please do not share unverified information externally.

5.5 Recovery

Objective: restore trusted services, validate integrity and reduce the chance of reinfection.

1. Confirm the affected scope and preserve evidence needed for investigation.
2. Identify and close initial-access paths; remediate exploited vulnerabilities and persistence.
3. Prepare a clean recovery environment and verify the integrity of backup sources.
4. Rebuild compromised systems from trusted images where appropriate.
5. Restore critical services in dependency order (identity first, then dependent services) and reset compromised credentials.
6. Test application function, data integrity, access controls and security monitoring.
7. Reconnect systems in controlled stages after authorised approval.
8. Monitor for recurrence and document recovery results.

Metric	Meaning	Example
RPO (Recovery Point Objective)	Maximum acceptable data loss, measured in time	4-hour RPO: recover to a point no more than four hours before disruption
RTO (Recovery Time Objective)	Target time to restore a service	8-hour RTO: restore within eight hours of the defined disruption point

Table 8. RPO and RTO.

Before reconnection

- Verify containment and address identified persistence.
- Confirm backup cleanliness and data integrity.
- Validate identity systems and privileged accounts before dependent services.
- Update security tools, patch vulnerable software and review network rules.
- Obtain documented technical and business approval to return to service.

> Successful file decryption is not proof of recovery. Systems must be trusted, monitored and protected against renewed access.

5.6 Safe Escalation

Objective: involve the right decision-makers quickly, using documented authority and verified channels.

Situation	Escalate to
Suspicious activity on one endpoint	SOC or designated IT security contact
Multiple endpoints showing encryption	Incident commander, SOC lead, network team
Privileged account or identity infrastructure compromise	Identity administrator, security lead, incident commander
Backup deletion or recovery infrastructure compromise	Backup lead, infrastructure lead, incident commander
Possible theft of personal or customer data	Incident commander, privacy/legal team
Critical service or safety-related disruption	Business continuity and operational/safety authorities
Potential criminal activity or reportable breach	Legal/compliance team and appropriate authorities

Table 9. Escalation matrix.

- Do not wait for complete proof before reporting a credible, active incident.
- Use the approved channel and record who was contacted and when.
- Do not make unauthorised ransom, disclosure or recovery decisions.
- Preserve evidence and avoid sharing confidential data with unapproved parties.
- Follow organisational and legal reporting requirements.

India reporting note. CERT-In's directions dated 28 April 2022, issued under Section 70B(6) of the Information Technology Act, 2000, require covered entities to report specified cyber incidents within six hours of noticing them. Confirm applicability, current wording and the reporting channel with the legal/compliance team.

6. Implementation Roadmap

A staged programme addresses the most urgent gaps first while building a sustainable response capability. The timeline is a proposed plan, not a compliance deadline; critical environments may need accelerated action.

Period	Priority actions	Expected output
Days 0-7	Inventory critical assets; confirm protected backups exist; verify MFA on admin and remote access; publish contact lists; identify exposed systems	Immediate risk reduction and a working escalation route
Days 8-30	Establish patch process; remove excess privileges; centralise key logs; test representative restores; document the response plan	Core controls and written procedures
Days 31-60	Expand EDR/SIEM coverage; build detections from Table 5; review segmentation; test compromised-account response and emergency communications	Improved detection and containment
Days 61-90	Run tabletop exercise; perform isolated restore; measure RPO/RTO; review supplier dependencies; assign corrective actions	Evidence-based readiness and improvement plan

Table 10. 90-day roadmap.

Roles and ownership

Role	Responsibility
Executive sponsor	Approve risk tolerance, resources and major incident decisions
Incident commander	Coordinate response, priorities, status and decisions
SOC / security lead	Triage, investigation, containment recommendations, evidence
IT / infrastructure	Network isolation, rebuilds, patching, system restoration
Backup administrator	Protect recovery copies; execute tested restores
Legal / privacy / communications	Assess notification duties; approve external messaging
Business service owner	Define impact and priorities; accept restored services

Table 11. Roles and responsibilities.

7. Findings, Results and Testing

7.1 Key findings

- Backup isolation and tested restoration are essential to reliable recovery.
- Least privilege, MFA and patch management reduce the most common attack paths.
- Endpoint monitoring is more effective when correlated with identity, network and backup logs.
- Clear authority and independent communication channels reduce response delay.
- Recovery must include clean rebuilds, validation and controlled reconnection.
- Exercises reveal gaps that written policies alone do not expose.

7.2 Readiness metrics

Metric	Suggested starting target	Evidence
Critical asset inventory coverage	100% of critical assets	Reviewed inventory
MFA for privileged and remote access	100% of in-scope accounts	Identity configuration report
Critical patch compliance	95%+ by approved deadlines; exceptions documented	Patch compliance report
Critical restore tests	All planned tests completed and validated	Restore logs
EDR coverage	All supported critical endpoints	Console coverage report
Escalation time	Measured against an approved target	Incident timestamps
Recovery objectives	Meet approved RTO/RPO in exercises	Exercise and restore results
Exercise findings	Critical findings closed by deadline	Action tracker

Table 12. Illustrative metrics; targets must be approved locally.

7.3 Tabletop scenario

A staff member reports unreadable files. EDR detects unusual file changes on the laptop. A file server then reports abnormal activity, and the backup administrator sees an unexpected backup-configuration change.

Expected response

1. Report and triage the alert; isolate the endpoint through approved procedures.

2. Protect backup infrastructure and investigate the configuration change.
3. Notify the incident commander and technical owners using verified channels.
4. Preserve evidence; assess scope including identity compromise and lateral movement.
5. Recover only from verified clean sources after containment and security validation.

Suggested injects and discussion questions

- Inject: corporate email becomes unavailable. *How is the team notified and who approves messages?*
- Inject: a threat actor claims to hold stolen data. *Who decides on disclosure and legal notification?*
- Inject: the most recent backup fails integrity checks. *Which earlier restore point is acceptable against the RPO?*
- Inject: a regulator-reportable incident is suspected. *Who files, and by when?*

> **Testing limitation**
> This report proposes an exercise and metrics; it does not claim that a live environment has been tested. Record actual evidence before reporting results as achieved.

8. Limitations and Recommendations

8.1 Limitations

- Zero-day vulnerabilities may be exploited before patches exist.
- Stolen sessions or weak account-recovery methods can undermine identity controls.
- Backups may be incomplete, corrupted, inaccessible or too slow to restore.
- Legitimate tools and valid credentials can be abused in ways that resemble normal activity.
- Third-party services introduce risks outside direct control.
- Small organisations may lack dedicated staff, specialist responders or recovery capacity.
- This report is a general synthesis. It is not an audit or legal opinion.

8.2 Recommendations

1. Maintain isolated, encrypted, regularly tested backups of critical systems and data.
2. Enforce least privilege, MFA and strong protection for administrative identities.
3. Prioritise patching of exposed and actively exploited vulnerabilities.
4. Deploy centrally managed endpoint monitoring; collect identity, server, network and backup logs.
5. Segment critical systems and tightly restrict remote access.
6. Document incident roles, containment authority and escalation thresholds.
7. Prepare independent communication channels and approved notification templates.
8. Define RPOs, RTOs, recovery priorities and clean-restore procedures.
9. Test through tabletop exercises and isolated restoration drills.
10. Assign owners and deadlines to significant security gaps.

8.3 Ransom payment considerations

Payment should never be treated as the default recovery strategy, and it guarantees neither data restoration nor confidentiality. Preserve the demand, consult senior management and legal counsel, assess recovery alternatives and any legal or sanctions restrictions, and document any decision through authorised governance. Law enforcement and CERT-In guidance should be consulted for the relevant jurisdiction.

9. Conclusion

Ransomware preparedness is an ongoing risk-management process, not a one-time tool installation. Effective preparation combines technical prevention, behavioural monitoring, rapid containment, trusted communication and validated recovery.

Backups provide resilience only when they are isolated and restorable. Least privilege and patching reduce attacker opportunity. Monitoring improves the chance of detecting malicious behaviour before it spreads. Safe escalation and clear communication enable coordinated decisions, and controlled recovery helps prevent reinfection.

> **Final thought**
> A ransomware-ready organisation is not one that assumes an attack will never happen. It is one that has practised how to respond when it does.

Final recommendation: appoint accountable owners, test recovery and escalation procedures regularly, and use measured results to improve resilience over time.

10. References and Appendices

10.1 References

[1] NIST (2026). *Ransomware Risk Management: A Cybersecurity Framework 2.0 Community Profile*, NIST IR 8374 Rev. 1 (final, 11 June 2026). Souppaya, M., Barker, W., Fisher, W., Kent, K. https://csrc.nist.gov/pubs/ir/8374/r1/final | DOI: 10.6028/NIST.IR.8374r1

[2] CISA. *#StopRansomware Guide*. https://www.cisa.gov/stopransomware/ransomware-guide

[3] NIST (2025). *SP 800-61 Rev. 3: Incident Response Recommendations and Considerations for Cybersecurity Risk Management*. https://csrc.nist.gov/pubs/sp/800/61/r3/final

[4] NIST (2024). *The NIST Cybersecurity Framework (CSF) 2.0*, NIST CSWP 29. https://www.nist.gov/cyberframework

[5] CERT-In. *Directions under sub-section (6) of Section 70B of the Information Technology Act, 2000* (28 April 2022). https://www.cert-in.org.in/

[6] MITRE. *ATT&CK Enterprise Matrix*. https://attack.mitre.org/

[7] Government of India. *National Cyber Crime Reporting Portal*. https://www.cybercrime.gov.in/

10.2 Appendix A: Quick response checklist

- Report suspicious activity through the approved channel.
- Isolate affected systems using approved procedures.
- Activate incident command and independent communication channels.
- Preserve logs and evidence; record timestamps and decisions.
- Protect backup infrastructure and privileged accounts.
- Assess scope, data exposure and notification duties.
- Restore only from verified clean sources after remediation and validation.
- Monitor for recurrence and complete a post-incident review.

10.3 Appendix B: Incident record fields

Incident ID; detection time and time zone; reporting person; affected assets; observed indicators; accounts involved; evidence references; containment actions; stakeholders notified; decisions and approvals; recovery status; regulatory assessment; lessons learned; corrective-action owners and deadlines.

10.4 Appendix C: India reporting note

CERT-In's directions dated 28 April 2022 include a six-hour reporting requirement for specified incidents applicable to covered entities. Confirm current directions, FAQs, applicability and the reporting channel with legal/compliance. A public cybercrime complaint does not automatically replace separate regulatory obligations.

10.5 Appendix D: Glossary

Term	Definition
EDR	Endpoint Detection and Response: endpoint telemetry, detection and response tooling
SIEM	Security Information and Event Management: central log correlation and alerting
MFA	Multi-factor authentication
Immutable backup	Backup that cannot be altered or deleted during its retention period

Term	Definition
Lateral movement	Attacker movement from one system to others inside a network
Double extortion	Combining data encryption with a threat to publish stolen data